

M2SR: Introduction a la Sécurité

Human in the Loop!

Master 1: SR/SI
Enseignant: Assane Gueye
Juin , 2024

« Cet outils est **incapable de stocker des clefs cryptographiques** de haute qualité et il a une **vitesse et une précision inacceptables** quand il effectue des opérations cryptographiques. (Il est aussi **encombrant, très difficile a manager** et il pollue l'environnement. **C'est vraiment extraordinaire qu'un tel outils continue a être produit et déployé.** Seulement, c'est un outils tellement omniprésent que nous sommes obligés de construire les protocoles de sécurité en tenant compte de leurs limitations. »

Kaufman, Perlman, & Speciner: « **Network Security—Private Communication in a Public World** », Prentice Hall, 1995

C'est quel outil?

Systèmes d'information

Collections de...

- Hardware!
- Logiciels (programmes, applications)
- Outils de stockage
- Données
 - En « repos »
 - En transit
- Les personnes

Protection

Principe No 1: Maillon Faible



Culture de sécurité

La sécurité est aussi une affaire de personnes, pas seulement de technique

- Sans une bonne formation, la technologie ne peut pas être efficace
- Les agressions contre le personnel organisationnel, y inclus les agressions directes, sont une tactique courante des agresseurs
- Plus de la moitié de toutes les failles de sécurité sont le résultat d'une erreur humaine ou sont compliquées par une erreur humaine
- **Une personne peut être votre plus gros atout ou votre maillon le plus faible en termes de sécurité**



Envoyer un homme sur la lune

Le Président John F. Kennedy a visité le siège de la NASA pour la première fois en 1961. Alors qu'il effectuait cette visite, **il se présenta au concierge qui nettoyait le sol et lui demanda ce qu'il faisait à la NASA.**

Le concierge répondit:

"J'aide à envoyer un homme sur la lune!"

De toute évidence, le concierge comprenait l'importance de sa contribution. Il croyait sincèrement qu'il était un élément précieux de quelque chose de plus grand que lui-même, et son attitude créait un sentiment de confiance en sa mission.

Il n'était pas seulement un concierge; il était un membre de l'équipe spatiale 1962 de la NASA!



Comment nous responsabilisons et motivons chaque employé à faire partie de l'Equipe de Sécurité?

Cibles humaines pour compromission

Criminals usually look for easy prey. But states can combine the criminal hacker's tricks, such as spear-phishing, with the intelligence apparatus to reconnoitre a target, the computing power to break codes and passwords, and the patience to probe a system until it finds a weakness—usually a fallible human being.



Menaces avancées et persistantes

La menace avancée et persistante - “Advanced Persistent Threat” (APT) est définie comme suit:

“... Une tendance à long terme d’attaques pirates ciblées, utilisant des moyens subversifs et dissimulés pour obtenir une exfiltration continue et persistante du capital intellectuel. **Le point d’entrée des activités d’espionnage est souvent l’utilisateur final qui ne se doute de rien** ou une sécurité faible du périmètre. La menace avancée et persistante est un agresseur avec des niveaux d’expertise/des ressources importantes, lui permettant, par l’utilisation de multiples vecteurs d’agression (par exemple, cyber, physique, et tromperie), de créer des occasions de réaliser ses objectifs qui sont généralement d’établir et d’étendre des ancrages dans l’infrastructure de technologie de l’information d’organisations dans le but de continuellement exfiltrer des informations et/ou de saper ou gêner les aspects critiques d’une mission, d’un programme, d’une organisation, ou de se mettre en position de le faire dans le futur. “

[NIST Publication Spéciale 800-30, page 9]

Le facteur humain dans la sécurité



“L’épaisseur d’un mur est moins importante que la volonté de le défendre” -
Thucydide, historien grec du Vème siècle avant J.C.

Les Attaques du Future (Intel)



Hacking the Human Operating System

- The role of social engineering within cybersecurity
- Techniques used in spear phishing
- How best to train employees from falling for social engineering scams
- <http://www.mcafee.com/us/resources/reports/rp-hacking-human-os.pdf>

Human-in-the-Loop

« Seuls les amateurs attaquent les machines; les professionnelles attaquent les utilisateurs »

Bruce Schneier

Security is too often merely an illusion, an illusion sometimes made even worse when gullibility, naivete, or ignorance come into play. The world's most respected scientist of the twentieth century, Albert Einstein, is quoted as saying, "Only two things are infinite, the universe and human stupidity, and I'm not sure about the former." In the end, social engineering attacks can succeed when people are stupid or, more commonly, simply ignorant about good security practices.

L'écosystème

Le saviez-vous?

- Il y'a autant d'attaques qui exploitent la « **psychologie** » que d'attaques qui exploitent la « **technologie** » (**ou même plus**)!
- L'hameçonnage est le cyber-crime le plus répandu.

McAfee Labs 2016 Threats Predictions

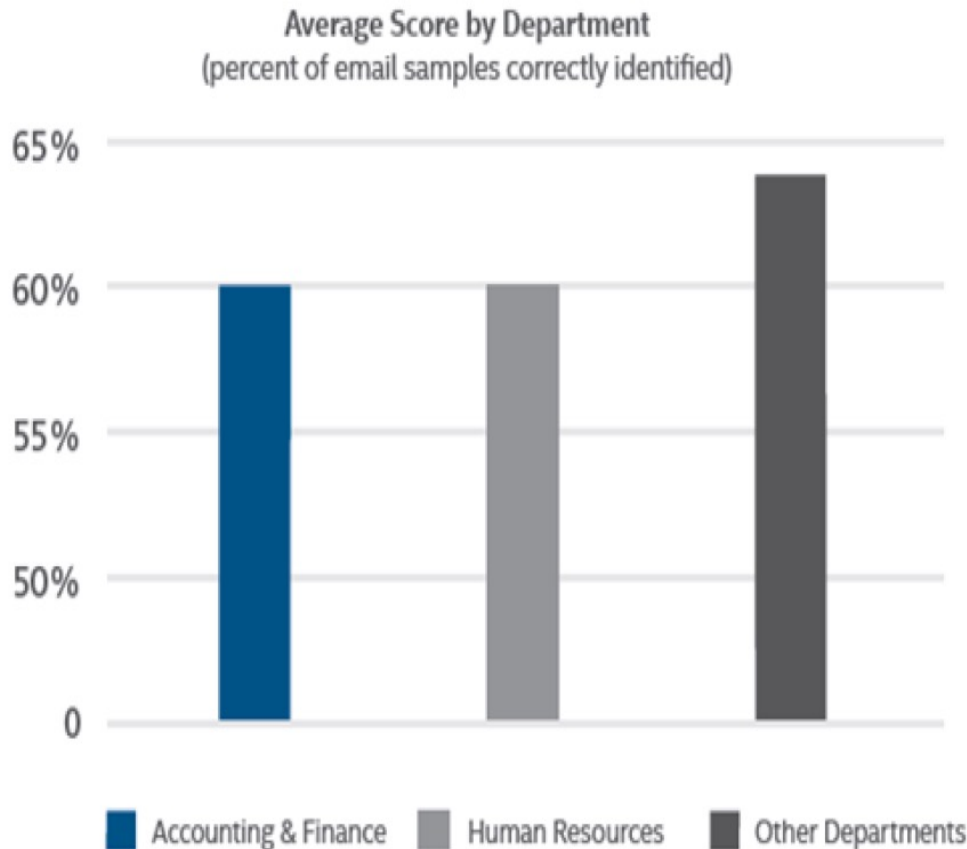
Attacks through employee systems

As direct attacks on business networks become more difficult, attackers will use home and public networks as their pathway into the business.



Phishing Quiz

Still the most effective means of delivering malware



95% of enterprise breaches are the result of successful spear phishing – Alan Paller, SANS

Only 6%

of all test takers **correctly identified** all ten email samples as phishing or legitimate.

80%

of all test takers **fell for at least one** of the seven phishing emails.

88%

of test takers in **Accounting & Finance and HR** fell for at least one of the seven phishing emails.

L'écosystème

Le saviez-vous?

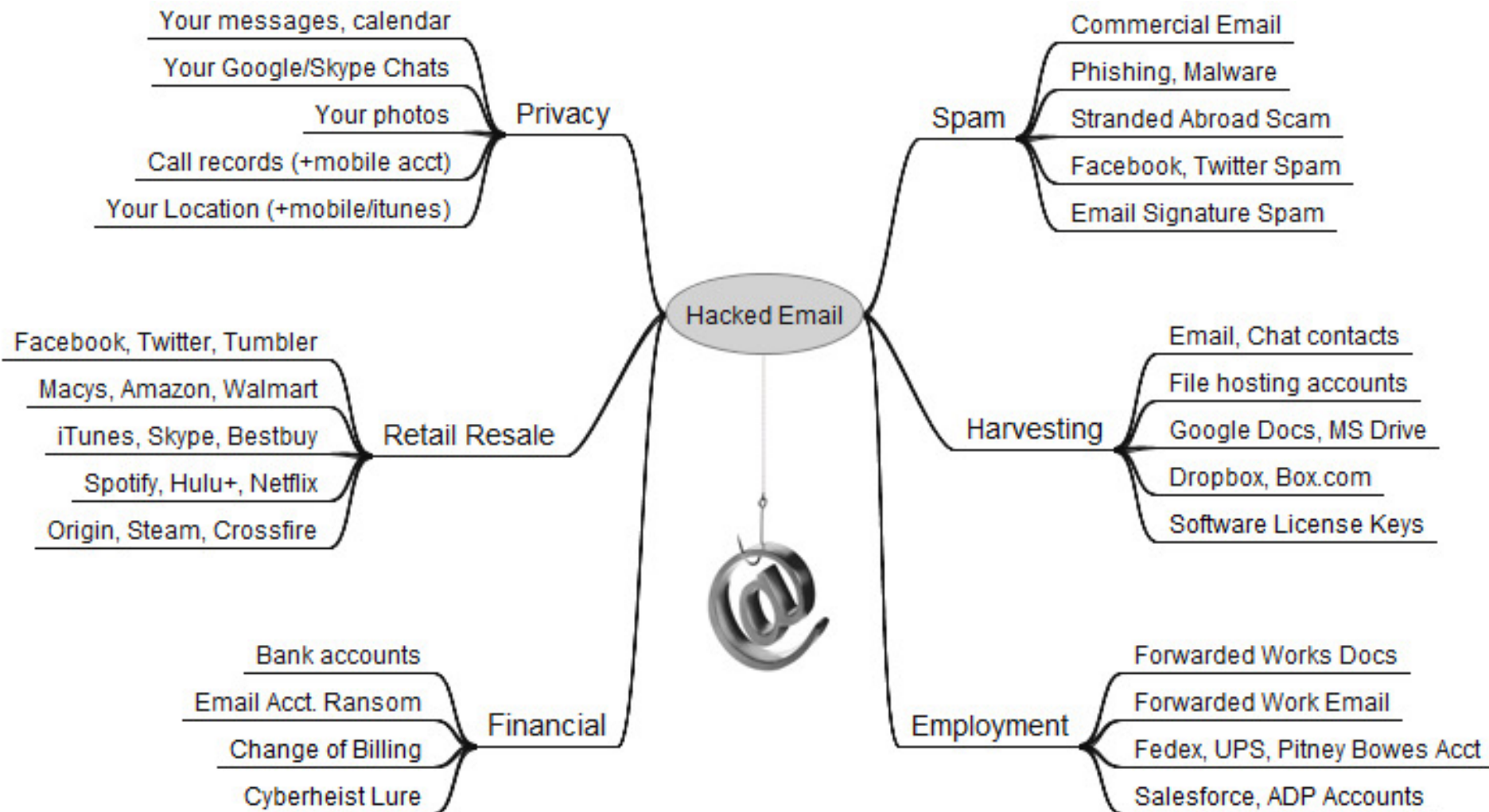
- Il y'a autant d'attaques qui exploitent la « **psychologie** » que d'attaques qui exploitent la « **technologie** » (**ou même plus**)!
 - L'hameçonnage est le cyber-crime le plus répandu.
 - **C'est aussi facile!**
 - Les fraudes en ligne...
 - Plus faciles
 - Plus difficile a déjouer et arrêter
- ... il est plus facile pour un criminel de construire une copie truquée du site de la banque que de braquer la banque!**

Fausse Conception!

Je ne suis pas une cible
intéressante. Personne
ne m'attaquera!



Mon email n'est aussi pas intéressant!



Ingénierie Sociale

La tromperie

Souvent utilise le téléphone

Cible les employés des entreprises

L'hameçonnage

Souvent utilise l'email

Cible les clients des entreprises

La tromperie

Souvent utilise le téléphone

Cible les employés des entreprises

La tromperie

WANTED BY U.S. MARSHALS

NOTICE TO ARRESTING AGENCY: Before arrest, validate warrant through National Crime Information Center (NCIC).

United States Marshals Service NCIC entry number: (NOC/ V721460021)

NAME:MITNICK, KEVIN DAVID

AKS (S):MITNIK, KEVIN DAVID
MERRILL, BRIAN ALLEN

DESCRIPTION:

Sex:MALE
Race:WHITE
Place of Birth:VAN NUYS, CALIFORNIA
Date(s) of Birth:08/06/63; 10/18/70
Height:5'11"
Weight:190
Eyes:BLUE
Hair:BROWN
Skin tone:LIGHT
Scars, Marks, Tattoos:NONE KNOWN



Kevin Mitnick!

[HOME PAGE](#)[TODAY'S PAPER](#)[VIDEO](#)[MOST POPULAR](#)[U.S. Edition ▼](#)

The New York Times

U.S.

[WORLD](#)[U.S.](#)[N.Y. / REGION](#)[BUSINESS](#)[TECHNOLOGY](#)[SCIENCE](#)[HEALTH](#)[SPORTS](#)[OPINION](#)[POLITICS](#) [EDUCATION](#) [TEXAS](#)

A Most-Wanted Cyberthief Is Caught in His Own Web

By JOHN MARKOFF,

Published: February 16, 1995

RALEIGH, N.C., Feb. 15— After a search of more than two years, a team of F.B.I. agents early this morning captured a 31-year-old computer expert accused of a long crime spree that includes the theft of thousands of data files and at least 20,000 credit card numbers from computer systems around the nation.

The arrest of Kevin D. Mitnick, one of the most wanted computer criminals, followed a 24-hour stakeout of an apartment building here.

[f FACEBOOK](#)[t TWITTER](#)[+ GOOGLE+](#)[✉ EMAIL](#)[+ SHARE](#)[🖨 PRINT](#)[📄 REPRINTS](#)

Kevin Mitnick!

Google Response!

Kevin Mitnick - The World's Most Famous Hacker

<https://www.mitnicksecurity.com/.../kevin-mitnick-worlds-most-famous-hacker-biogr...> ▼

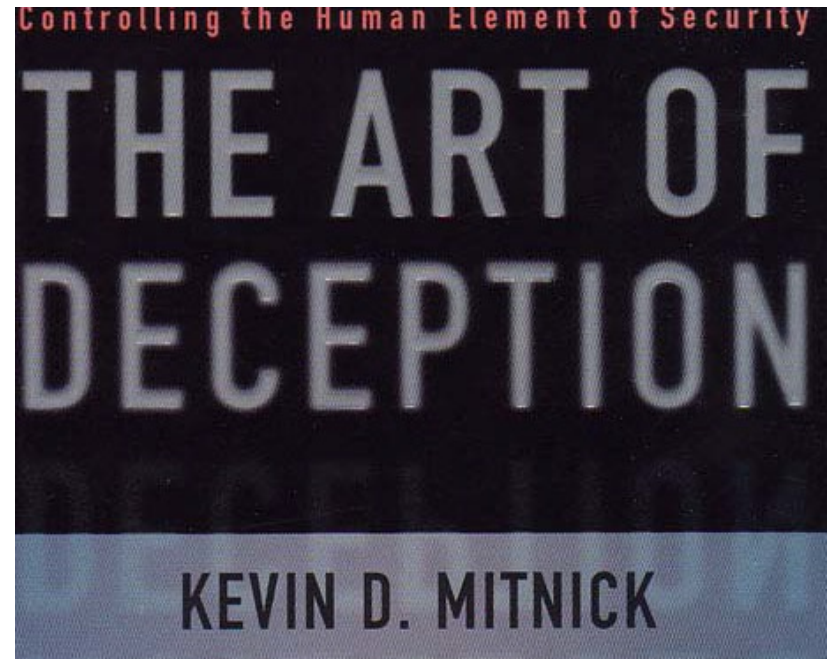
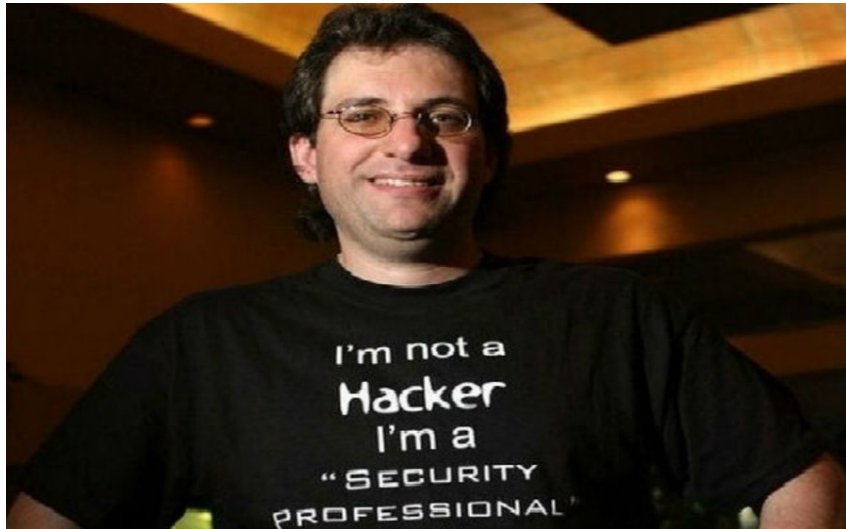
Kevin Mitnick's Laptop as His Head **Kevin Mitnick** is the world's most famous hacker, bestselling author, and the top cyber security speaker. Once one of the FBI's ...

The World's Top Security Testing Team | Mitnick Security

<https://mitnicksecurity.com/> ▼

The world's most famous hacker **Kevin Mitnick** leads an elite white-hat team to provide the planet's best penetration testing, security assessments and training.

Kevin Mitnick!



Kevin Mitnick: The Art of Deception

Chapter 1 **Security's Weakest Link**

A company may have purchased the best security technologies that money can buy, trained their people so well that they lock up all their secrets before going home at night, and hired building guards from the best security firm in the business.

 That company is still totally Vulnerable.

Kevin Mitnick: The Art of Deception

Page 14

Code Breaking

One day in 1978, Rifkin moseyed over to Security Pacific's authorized-personnel-only wire-transfer room, where the staff sent and received transfers totaling several billion dollars every day.

He was working for a company under contract to develop a backup system for the wire room's data in case their main computer ever went down. That role gave him access to the transfer procedures, including how bank officials arranged for a transfer to be sent. He had learned that bank officers who were authorized to order wire transfers would be given a closely guarded daily code each morning to use when calling the wire room.

In the wire room the clerks saved themselves the trouble of trying to memorize each day's code: They wrote down the code on a slip of paper and posted it where

Kevin Mitnick: The Art of Deception

Page 14

Arriving in the wire room, he took some notes on operating procedures, supposedly to make sure the backup system would mesh properly with the regular systems. Meanwhile, he surreptitiously read the security code from the posted slip of paper, and memorized it. A few minutes later he walked out. As he said afterward, he felt as if he had just won the lottery.

There's This Swiss Bank Account...

Leaving the room at about 3 o'clock in the afternoon, he headed straight for the pay phone in the building's marble lobby, where he deposited a coin and dialed into the wire-transfer room. He then changed hats, transforming himself from Stanley Rifkin, bank consultant, into Mike Hansen, a member of the bank's International Department.

According to one source, the conversation went something like this:

"Hi, this is Mike Hansen in International," he said to the young woman who answered the phone.

She asked for the office number. That was standard procedure, and he was prepared: "286" he said.

The girl then asked, "Okay, what's the code?"

Rifkin has said that his adrenaline-powered heartbeat "picked up its pace" at this point. He responded smoothly, "4789." Then he went on to give instructions for wiring "Ten million, two-hundred thousand dollars exactly" to the Irving Trust Company in New York, for credit of the Wozchod Handels Bank of Zurich, Switzerland, where he had already established an account.

The girl then said, "Okay, I got that. And now I need the interoffice settlement number."

Rifkin broke out in a sweat; this was a question he hadn't anticipated, something that had slipped through the cracks in his research. But he managed to stay in character, acted as if everything was fine, and on the spot answered without missing a beat, "Let me check; I'll call you right back." He changed hats once again to call another department at the bank, this time claiming to be an employee in the wire-transfer room. He obtained the settlement number and called the girl back.

She took the number and said, "Thanks." (Under the circumstances, her thanking him has to be considered highly ironic.)

Kevin Mitnick: The Art of Deception

Confiance!!!

Page 44

TRUST: THE KEY TO DECEPTION

The more a social engineer can make his contact seem like business as usual, the more he allays suspicion. When people don't have a reason to be suspicious, it's easy for a social engineer to gain their trust.

Once he's got your trust, the drawbridge is lowered and the castle door thrown open so he can enter and take whatever information he wants.

Kevin Mitnick: The Art of Deception

Confiance!!!

Page 44

The First Call: Andrea Lopez

Andrea Lopez answered the phone at the video rental store where she worked, and in a moment was smiling: It's always a pleasure when a customer takes the trouble to say he's happy about the service. This caller said he had had a very good experience dealing with the store, and he wanted to send the manager a letter about it.

He asked for the manager's name and the mailing address, and she told him it was Tommy Allison, and gave him the address. As he was about to hang up, he had another idea and said, "I might want to write to your company headquarters, too. What's your store number?" She gave him that information, as well. He said thanks, added something pleasant about how helpful she had been, and said goodbye.

Kevin Mitnick: The Art of Deception

Confiance!!!

Page 44

The Second Call: Ginny

"Thanks for calling Studio Video. This is Ginny, how can I help you?"

"Hi, Ginny," the caller said enthusiastically, sounding as if he talked to Ginny every week or so. "It's Tommy Allison, manager at Forest Park, Store 863. We have a customer in here who wants to rent *Rocky 5* and we're all out of copies. Can you check on what you've got?"

She came back on the line after a few moments and said, "Yeah, we've got three copies."

"Okay, I'll see if he wants to drive over there. Listen, thanks. If you ever need any help from our store, just call and ask for Tommy. I'll be glad to do whatever I can for you."

Three or four times over the next couple of weeks, Ginny got calls from Tommy for help with one thing or another. They were seemingly legitimate requests, and he was always very friendly without sounding like he was trying to come on to her. He was a little chatty along the way, as well - "Did you hear about the big fire in Oak Park? Bunch of streets closed over there," and the like. The calls were a little break from the routine of the day, and Ginny was always glad to hear from him.

Kevin Mitnick: The Art of Deception

Confiance!!!

Page 44

One day Tommy called sounding stressed. He asked, "Have you guys been having trouble with your computers?"

"No," Ginny answered. "Why?"

"Some guy crashed his car into a telephone pole, and the phone company repairman says a whole part of the city will lose their phones and Internet connection till they get this fixed."

"Oh, no. Was the man hurt?"

"They took him away in an ambulance. Anyway, I could use a little help. I've got a customer of yours here who wants to rent *Godfather II* and doesn't have his card with him. Could you verify his information for me?"

"Yeah. sure."

Kevin Mitnick: The Art of Deception

Confiance!!!

Page 44

Tommy gave the customer's name and address, and Ginny found him in the computer. She gave Tommy the account number.

"Any late returns or balance owed?" Tommy asked.

"Nothing showing."

"Okay, great. I'll sign him up by hand for an account here and put it in our database later on when the computers come back up again. And he wants to put this charge on the Visa card he uses at your store, and he doesn't have it with him. What's the card number and expiration date?"

She gave it to him, along with the expiration date. Tommy said, "Hey, thanks for the help. Talk to you soon," and hung up.



I was victim of an online scam

19 messages

Mon, Nov 8, 2021 at 3:13 PM

Dear Friends,

I was recently a victim of a scam in which I ended up losing some money (not much, alhamdulillah). I cannot share the details because a police report has been filed and investigations are ongoing, but I wanted to talk about the strategies that were used to make the scam look real and share with you some recommendations, hoping that it will prevent other people from falling in the same trap. Please feel free to share with others.

It is the usual scam where you are told that a friend is in a difficult position and needs your help.

Strategy 1: Use the victim's emotion

The scammers put together a plot in which a very good friend was involved in an accident with their family (scammers have the names). The "fake" accident involved fatalities and my "fake" friend ended up being arrested by the police and needed to be bailed out, and a member of his family was unconscious at the hospital.

Strategy 2: Information about the victim

Scammers were able to use information about me and my family and about a friend of mine and his family as well. They had my friend's name as well as names of members of his family. They had my phone number and my wife's phone number (and called us both). They also knew that we were good friends and we would likely be willing to help "our friend". Putting together these pieces of information made the plot seem "real".

Strategy 3: Good knowledge of the US legal system

The scam involved someone who claimed to be from the police department and someone who claimed to be a public defendant (they called us at different times). The scammers used information and language that law enforcement people use. They also understand very well the process of reporting a case to family member and what processes are put in place when someone gets arrested.

Also, they had the addresses and phone numbers of police departments as well as public defendants and bailbonds agencies.

L'hameçonnage (Phishing)



« Tentative de soutirer des informations sensibles comme les logins, mot de passe, numéro de carte de crédit, etc..., souvent en se présentant comme une entité de confiance dans une communication électronique »

L'hameçonnage

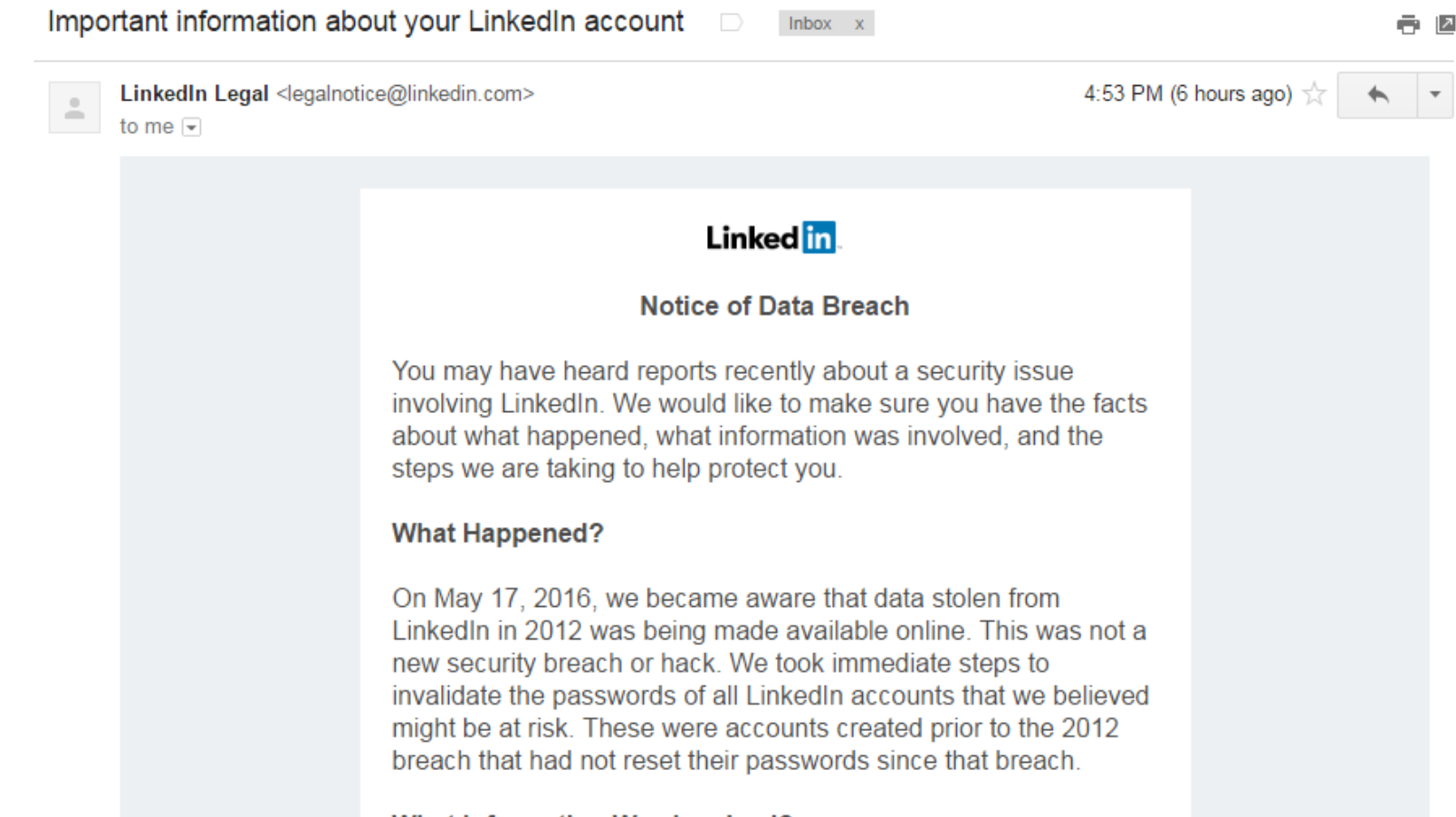
Souvent utilise l'email (mais aussi la tromperie)
Cible les clients des entreprises

Bonjour, ici le service de sécurité de votre banque. Nous venons de constater que quelqu'un a essayé d'acheter une pièce d'or avec. Est-ce que vous pouvez me donner votre PIN pour que je puisse passer à la désactivation?



L'hameçonnage

Email de tromperie: se faire passer pour une compagnie légitime (exemple: paypal, google)



L'hameçonnage

Harponnage (spear phishing): bien cible la victime en mentionnant son nom, fonction, téléphone, adresse etc...

Votre adresse Gmail, assanegue29@gmail.com, a été créée.

Inbox x



L'équipe Gmail <mail-noreply@google.com>
to me ▾

May 29 (1 day ago) ☆



French ▾

> English ▾

[Translate message](#)

[Turn off for: French](#) x

Bienvenue dans Gmail ! Vous pouvez vous connecter à votre compte à l'adresse <http://mail.google.com/>.

Les quelques conseils qui suivent vous aideront à bien démarrer.

- **Les outils d'importation de Gmail** vous aideront à [importer les messages et les contacts](#) de vos autres comptes de messagerie vers votre nouvelle adresse Gmail.
- **Pour rester connecté lorsque vous êtes en déplacement**, vous pouvez télécharger l'application mobile pour [Android](#), ou pour [iPhone et iPad](#).

Si vous rencontrez des difficultés avec votre compte ou si vous oubliez votre mot de passe, nous utiliserons cette adresse pour entrer en contact avec vous.

Nous espérons que vous apprécierez votre nouvelle messagerie !

L'équipe Gmail

Si vous n'avez pas créé cette adresse Gmail et si vous ne reconnaissez pas cet e-mail, nous vous invitons à accéder à la page https://accounts.google.com/AccountDisavow?adt=AOX8kipSuXcgXtghubhIS-XcLADpA1DUmuD6KgYAPraatL_TG6fI0S67ka3Fk4zQVg pour supprimer le lien avec ce compte.

L'hameçonnage

La peur du boss (CEO Fraud): utiliser une adresse email similaire a celui de l'autorité supérieures pour donner des ordres

Business Email Compromise Scam Alert Issued by FS-ISAC



DAVID BISSON

[Follow @DMBisson](#)

JUN 25, 2015 |

LATEST SECURITY NEWS



SECURITY
NEWS

L'hameçonnage

Pharming: usurper le nom de domaine d'un site web et l'utiliser pour détourner les visiteurs sur un autre site

Fraudsters hijack a website's domain name and use it to redirect visitors to an imposter site.

SCAM'S OBJECTIVE:
To intercept and steal online payments.

HOW TO AVOID IT:
Check that the URL of any site asking for data is authentic – look for the secure certificate.



The illustration shows a cartoon hacker with orange hair, a black mask, and a blue shirt. He is holding a long pole with a hook at the end, which is lifting a green rectangular sign that says 'MYSITE' in white capital letters. The sign is being lifted from a computer monitor. The monitor displays the text 'www.MYSITE.com' in red. The hacker is standing next to a black keyboard. The background is a solid teal color.

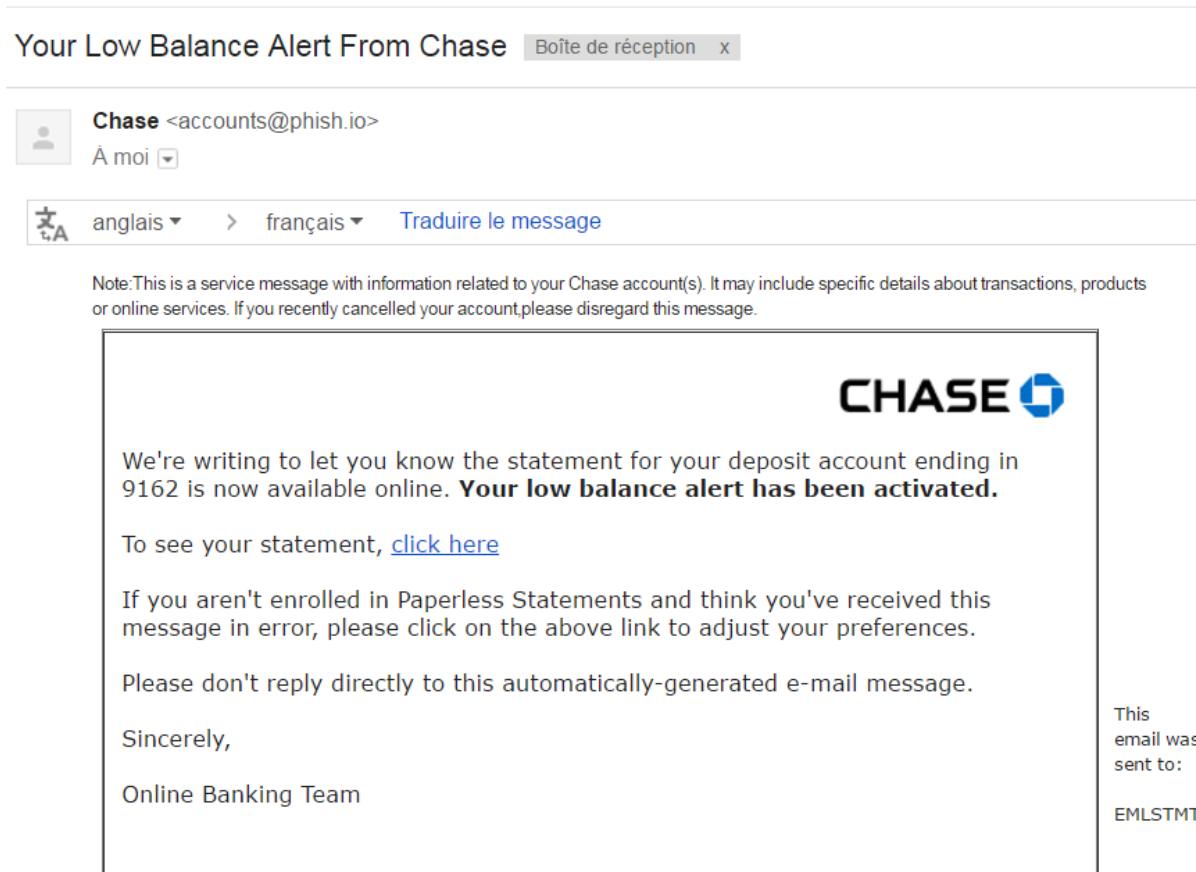
L'hameçonnage

Documents partagés: utiliser les outils de partage de document (GoogleDrive, Dropbox, etc.) pour inciter à visiter le mauvais document ou **demander le mot de passe!**



L'hameçonnage

La mauvaise pièce jointe et le mauvais lien: attacher un document infecte ou un lien sur le mauvais site

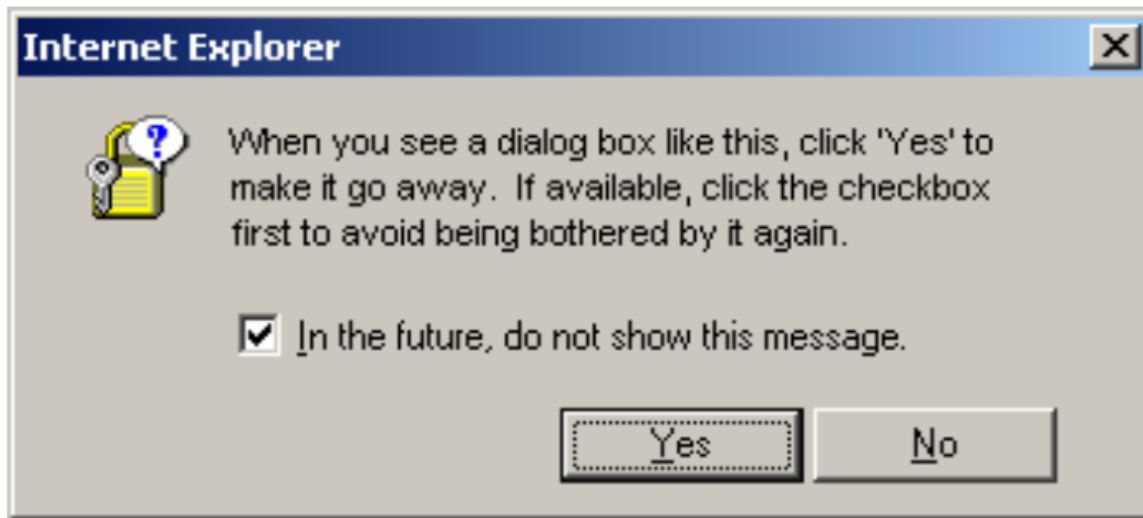


If you are reading this, you probably already know that this is a phishing test! It was sent by Assane@yewou.com

Sécurité et Psychologie

Erreur humaine

- « Habitude »:
e.g., cliquer sur 'OK' (juste par habitude)



Sécurité et Psychologie

Erreur humaine

- « Habitude »:
e.g., cliquer sur 'OK' (juste par habitude)
- Erreur dans la procédure/operation
Utiliser la règle la plus contraignante ou la plus générale au lieu de la plus efficace.
e.g., <https://www.citibank.secureauthentication.com>
e.g., chercher la signe du « cadenas »
- Erreur dans la réflexion
Inciter l'utilisateur a appliquer la mauvaise logique

L'hameçonnage

Vérification: **URL différent**



eBay sent this message from (pajv21).
Your registered name is included to show this message originated from eBay. [Learn more.](#)

Message from eBay member , pajv21



Do not respond to the sender if this message requests that you complete the transaction outside of eBay. This type of offer is against eBay policy, may be fraudulent, and is not covered by buyer protection programs. [Learn More.](#)

I can do for \$385.00 with shipping. Waiting for your answer asap.

Thank you.

Did this answer your question? If not, let the seller know.

Respond

View Item: <http://cgi.ebay.com/ws/eBayISAPI.dll?ViewItem&item=130312669787>

Item Id: [130312669787](#)

End time: Mar 03, 2011 09:38:06 PDT

Buyer: [pajv21](#) ([381](#) ★)

Feedback: **100 % Positive**

Member: since 26-May-06

Location: United States

Listing Status: This message was sent while the listing was **active**.

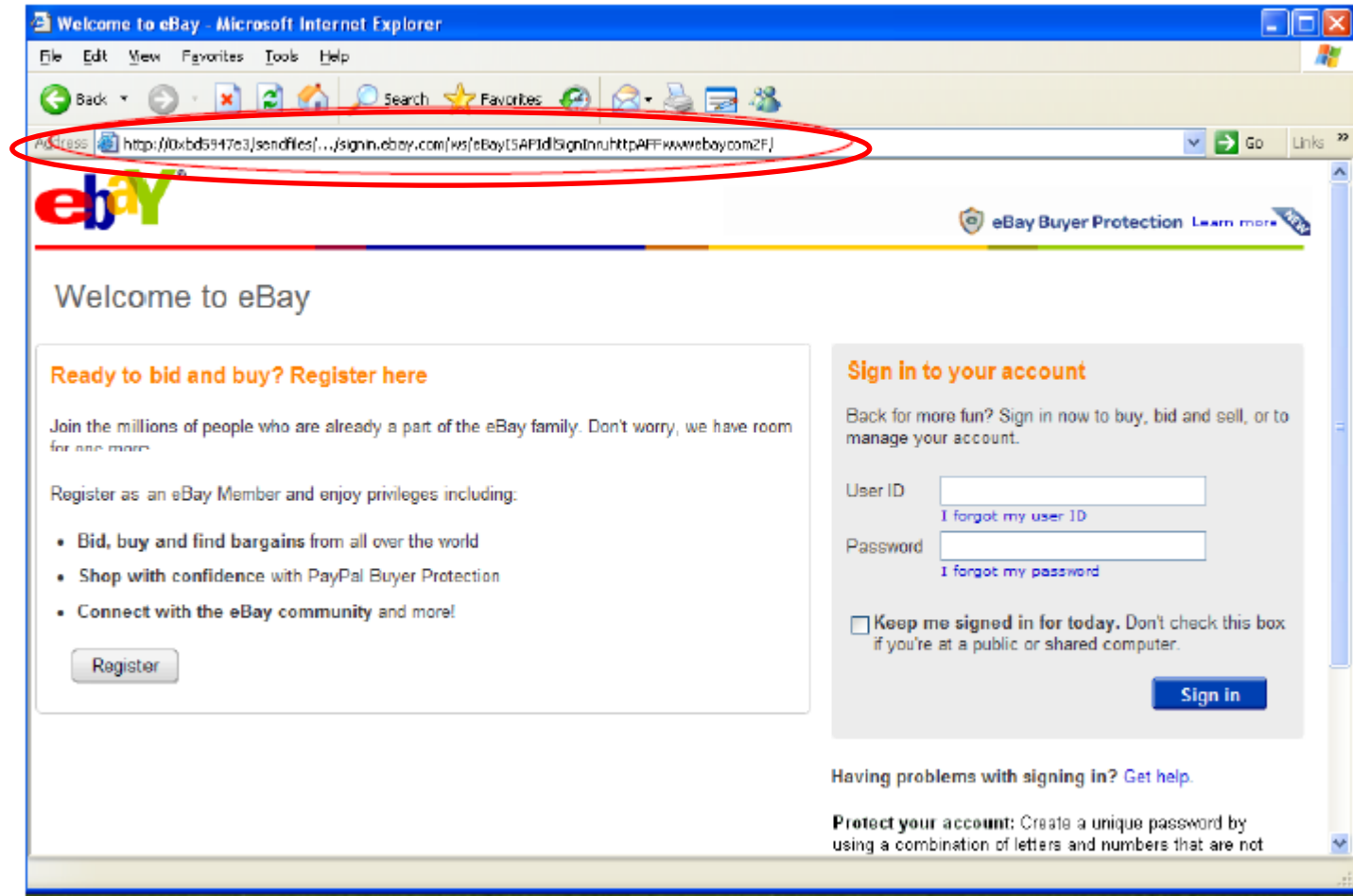
Marketplace Safety Tip

- Keep your money safe - never pay for items with cash or instant money transfer services, such as Western Union or MoneyGram. In the past some sellers have exploited these payment methods in order to defraud buyers, so eBay has banned them from the site.

<http://gpn172.internetdsl.tpnet.pl/apache2-default/dostawcy/incom/./cepim4723.htm>

L'hameçonnage

Vérification: **Code sur la barre d'adresse**



Address  `http://0xbd5947e3/sendfiles/.../signin.ebay.com/ws/eBayISAPI.dll?SignInhttpAFFwwwwebaycom2F/`

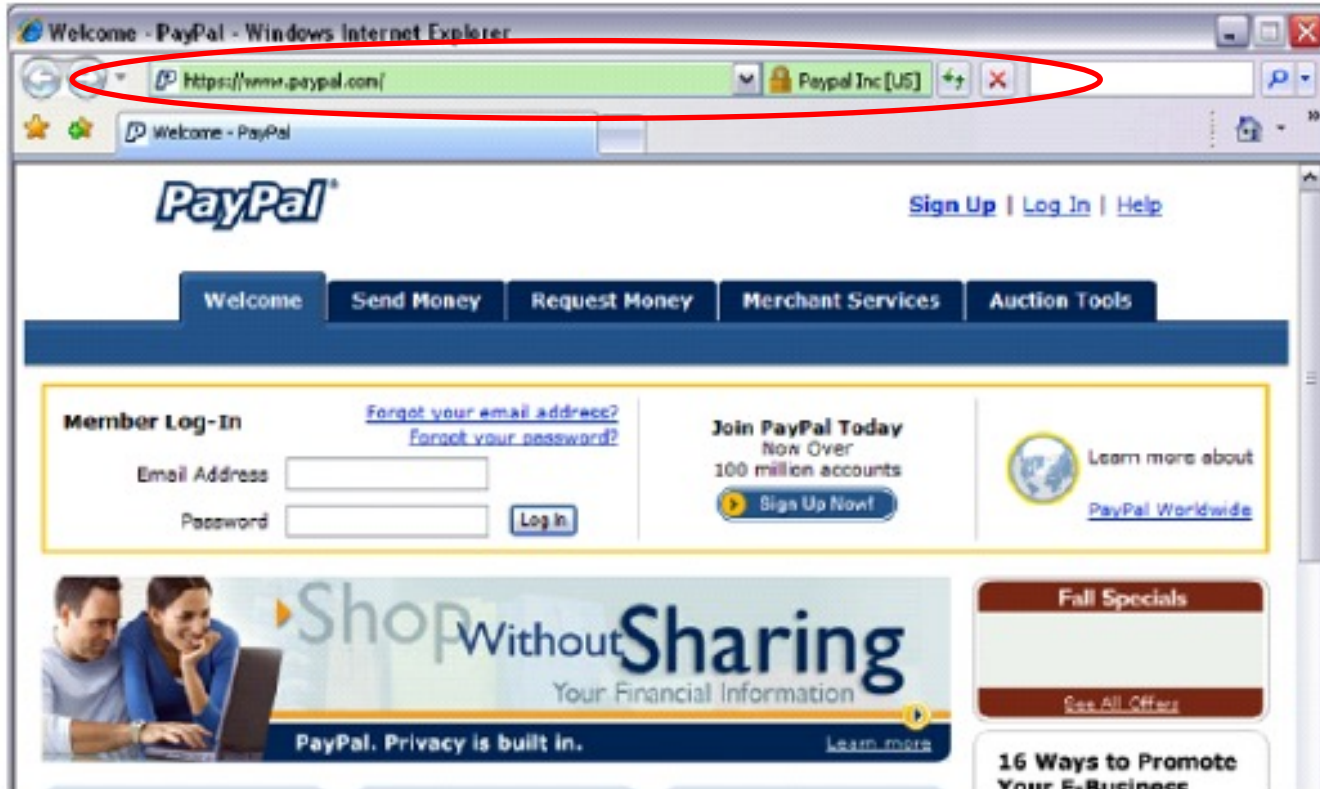
L'hameçonnage

Vérification: Chercher le cadenas!



L'hameçonnage

Vérification: Couleur verte de la barre d'adresse



L'hameçonnage

Est-ce que cet email est légitime?

De : "Université de Toronto" <univ.toronto@torontomail.com>
Date: ven. 28 juin 2019 à 17:52
Subject: Admission – Présenter une demande de permis d'études.
To: <[REDACTED]>
Cc: <[REDACTED]>



Université de Toronto

Adresse: [27 King's College Cir., Toronto, ON M5S 3H7, Canada](#)

Téléphone: [+1 \(514\) 600-6349](#)

Courriel: univ.toronto@torontomail.com

Cher postulant: [REDACTED]

Nous vous confirmons votre admission à la demande de bourse d'étude étrangère adressée à notre bureau en date du 19 Juin 2019 pour la Session d'Inscription 2019.

Généralement, les ressortissants étrangers doivent obtenir un permis d'études afin de pouvoir étudier au Canada. Un permis d'études est habituellement valide durant votre programme d'études, plus 90 jours. Cette période supplémentaire vous permet de vous préparer à quitter le Canada ou de présenter une nouvelle demande afin de prolonger votre séjour.

Avant de présenter une demande de permis d'études, vous devez obtenir une lettre d'acceptation d'un établissement d'enseignement désigné. En foi de quoi la lettre d'admission ci-jointe à ce courriel a été délivrer par l'Université de Toronto pour vous servir et valoir ce que de droit.

La lettre d'admission doit être téléchargé, lire, signé et précéder de la mention lu et approuvé du postulant.

L'Université de Toronto requiert votre dossier de demande de permis d'étude. Ainsi donc, nous vous faisons parvenir en annexe à la présente correspondance, les formulaires de demande de permis d'études. Ces formulaires sont valables pour tous les niveaux d'études.

Votre dossier de demande de permis d'étude doit être envoyé par pièce ci-jointe à l'adresse email du Bureau de la Mission Résidente de l'Université de Toronto, en Afrique de l'Ouest au Bénin.

Faite une bonne lecture du Certificat de Garantie établir par le ministère de l'Enseignement supérieur, de la Recherche et de la Science (MESRS) du Gouvernement du Canada. Le certificat vous garantie une exclusive vue sur les investissements que vous aurez à effectuer auprès du Bureau de la Mission Résidente de l'Université de Toronto. Retenez bien qu'il est fortement interdit d'entrer en contact avec un tout autre bureau que le Bureau de la Mission Résidente de l'Université de Toronto en Afrique de l'Ouest au Bénin. Ainsi donc notez correctement les coordonnées du bureau.

Faite une bonne lecture du Certificat de Garantie établi par le ministère de l'Enseignement supérieur, de la Recherche et de la Science (MESRS) du Gouvernement du Canada. Le certificat vous garantit une exclusive vue sur les investissements que vous aurez à effectuer auprès du Bureau de la Mission Résidente de l'Université de Toronto. Retenez bien qu'il est fortement interdit d'entrer en contact avec un tout autre bureau que le Bureau de la Mission Résidente de l'Université de Toronto en Afrique de l'Ouest au Bénin. Ainsi donc notez correctement les coordonnées du bureau.

Mission Résidente de l'Université de Toronto

Lot 413, Zone résidentielle, 03 BP 0501 Cotonou - Bénin

Téléphone : (+229) 65 52 12 33

Courriel : m.residente.utoronto@representative.com

Documents requis pour la constitution de votre dossier de demande de permis d'études:

(Copie Scannée)

- Remplissez lesdits formulaires uniquement et seulement à l'écran ;
- Lettre d'admission signée précédé de la mention lu et approuvé ;
- Bordereau de versement des frais de demande de permis d'étude (150 CAD - Dollar Canadien).

Pour des raisons de sécurité de votre transaction, les frais de demande de permis d'études doivent être transférer uniquement les services de transfert d'argent 'WESTERN UNION' ou 'MONEY GRAM' et cela à l'adresse du comptable du Bureau de la Mission Résidente de l'Université de Toronto au Bénin soit ci-dessous:

Nom: LIGAN
Prénom: Eric
Pays: BÉNIN
Ville: COTONOU

Conformément aux dispositions de l'article 51 du Décret n°2008-817 la 31/12/2008 portant attribution, organisation et fonctionnement du ministère de l'Enseignement supérieur, de la Recherche et de la Science (MESRS), le Bureau de la Mission Résidente de l'Université de Toronto se fera le devoir d'introduire votre demande de permis d'études avec validation et autorisation du Bureau du Registraire de L'université de Toronto.

Nous vous rappelons que la sincérité des informations contenues sur le Certificat de Garantie est indispensable. Veuillez envoyer dans un bref délai, votre dossier de demande de permis d'études à l'adresse email de la Mission Résidente de l'Université de Toronto au Bénin.

Nota : Votre permis d'études n'est pas un visa. Il ne vous donne pas le droit, à lui seul, d'entrer au Canada.

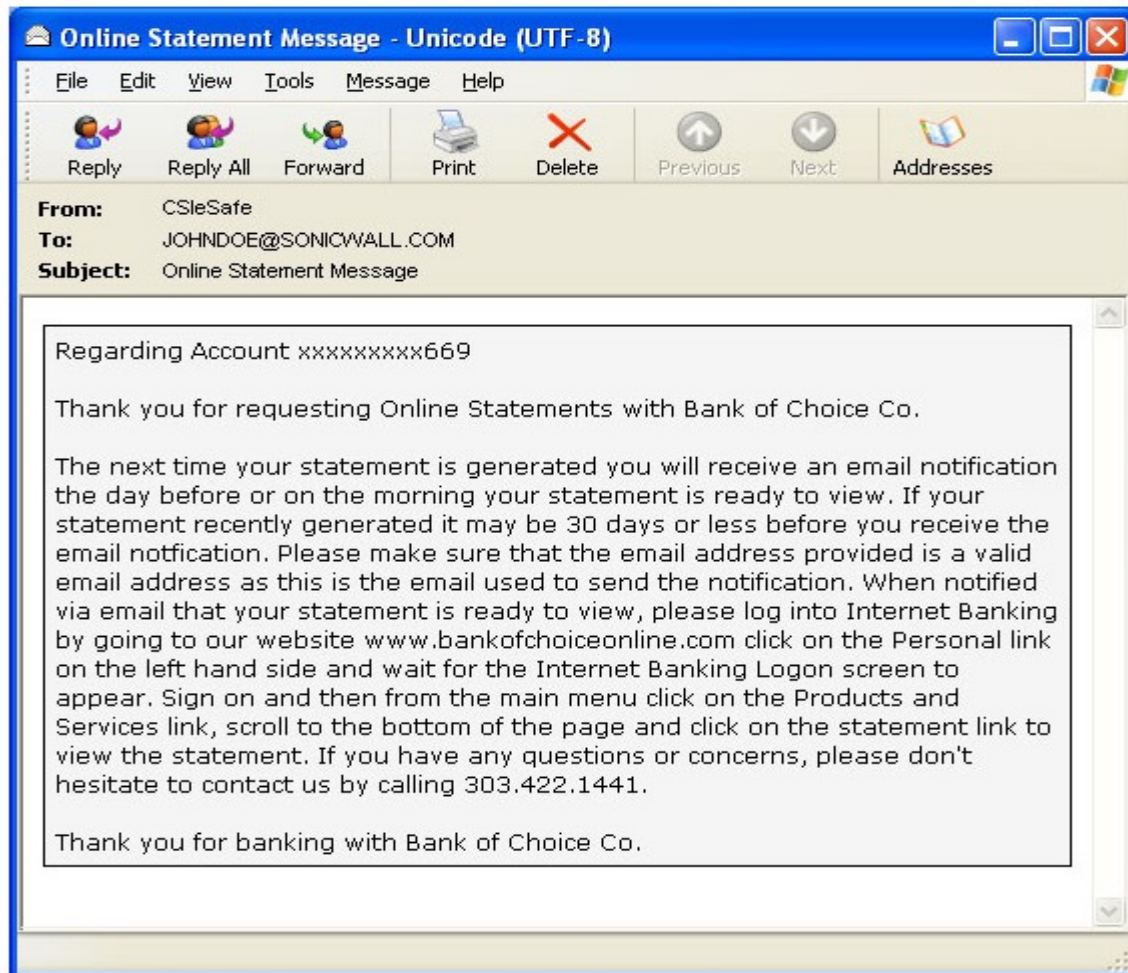
Vos diligences et promptitudes seront hautement appréciées.
En attente de votre dossier de demande de permis d'études.



UNIVERSITY OF
TORONTO

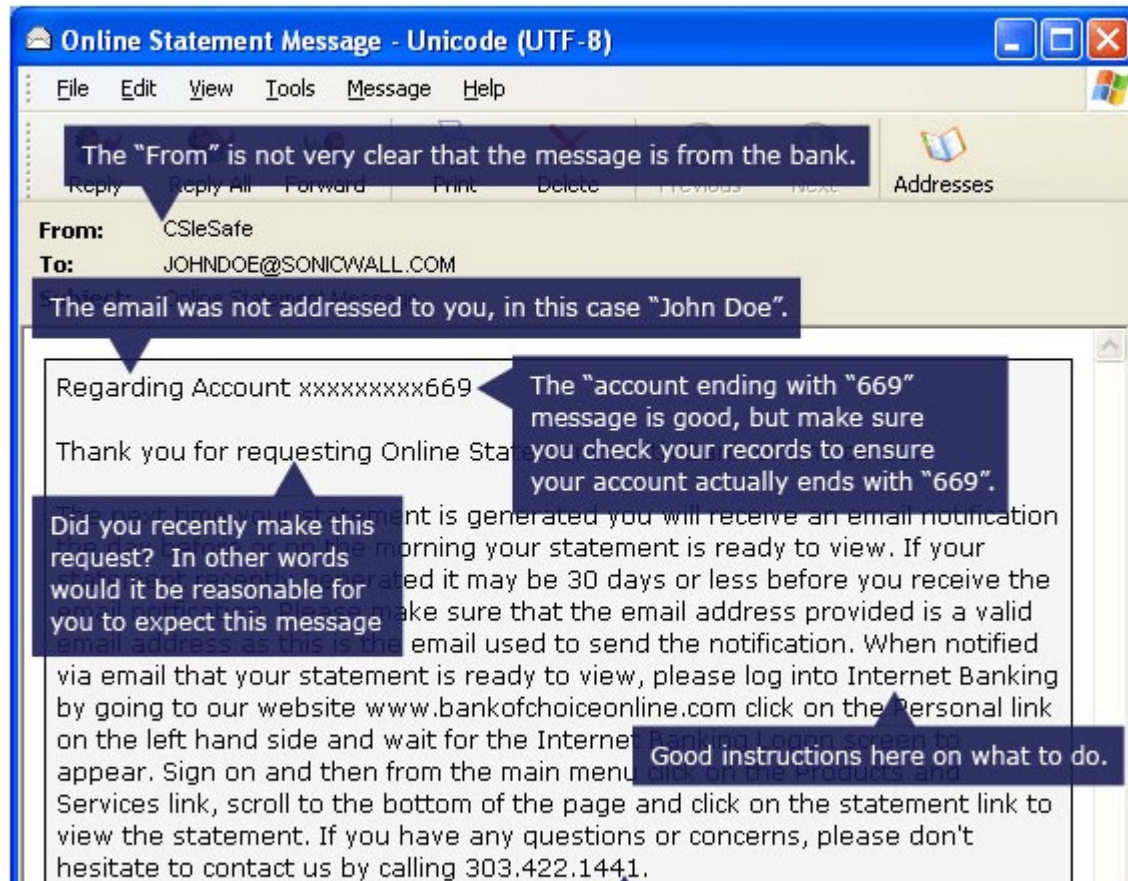
L'hameçonnage

Est-ce que cet email est légitime?



L'hameçonnage

Est-ce que cet email est légitime? **OUI!**



L'hameçonnage

Est-ce que cet email est légitime?

Bank of America: Account CLOSED

email alert (email.alert@bankofamerica.com) [Add contact](#)

To: alvcjqzvw@hrvatskamail.com;

>

To ensure delivery, add onlinebanking@ealerts.bankofamerica.com to your address book.

Bank of America 



Online Banking Alert

To: **DEAR CUSTOMER**

Account: **CHECKING**

Date: **12/09/2011**

The most recent **ALERTS** for your account are now available to download online.

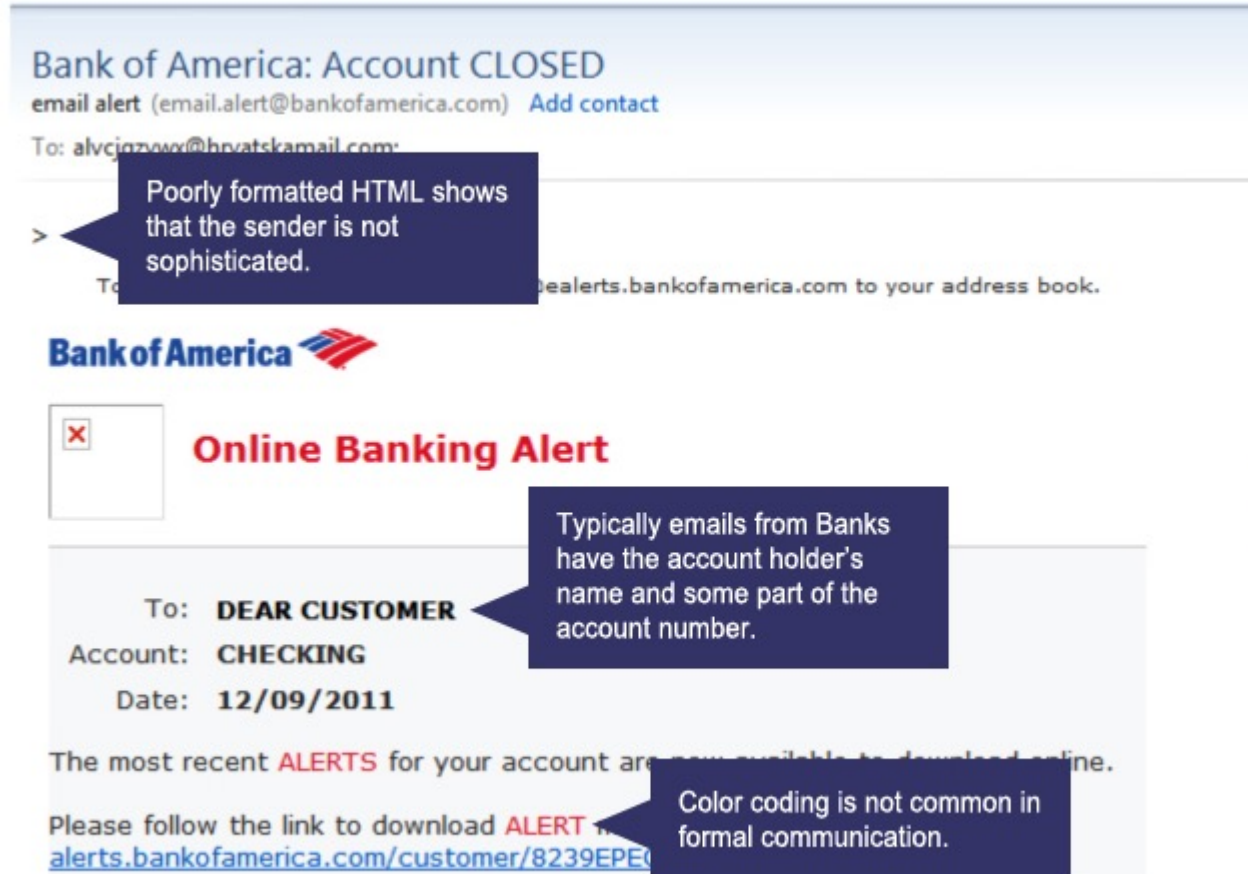
Please follow the link to download **ALERT** message here
alerts.bankofamerica.com/customer/8239EPEOIQ89534/

Set up Alerts to be notified 5 days before your payment is due to help avoid late payments. Sign in to Online Banking and select the Alerts tab to activate the Credit Card Payment Due Alert.

Want to confirm this email is from Bank of America? Sign in to Online Banking and go to Alerts. The Alerts History lists the Alerts sent to you in the past 60 days.

L'hameçonnage

Est-ce que cet email est légitime? **NON!**



ame
t

L'hameçonnage

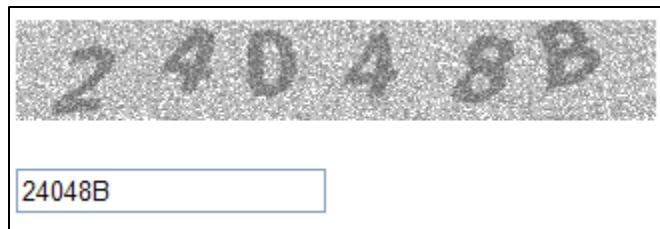
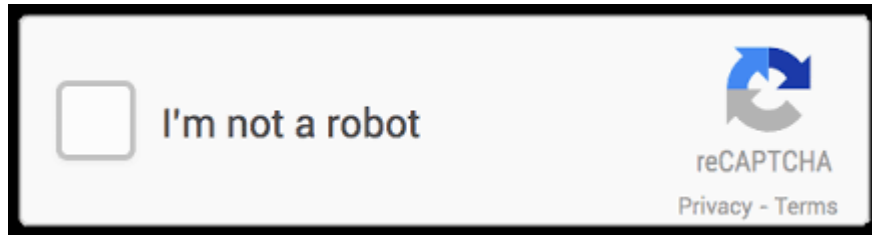
Mesures de control:

- **Plug-ins** (Transformateur de mot de passe)
 - Calcule un hash du mot de passe de l'utilisateur
 - Problèmes quand on change de navigateur
- **Certificat de navigateur**
 - Chercher le cadenas!
 - Vol de certificat: *"Your certificate has expired, please send them back to us for secure destruction!"*
- **Outils d'alerte**
 - Navigateur change de couleur quand l'utilisateur visite un site d'hameçonnage
 - Attaque picture-on-picture
- **Authentification en 2 étapes**
 - Mot de passe + token (RSA SecureID)
 - Attaque Man-in-the-Middle
- **Authentification en 2 canaux**
 - Mot de passe + code sur téléphone
 - Ne voyage pas, ne perd pas ton téléphone!
- **CAPTCHAs** (Quand l'humain est meilleur que la machine)

L'hameçonnage

Mesures de control:

- **CAPTCHAs** (Quand l'humain est meilleur que la machine)
« **Completely Automated Public Turing Test to Tell Computers and Humans Apart** »



Sécurité et Mot de Passe!

Challenges avec Mot-de-Passe

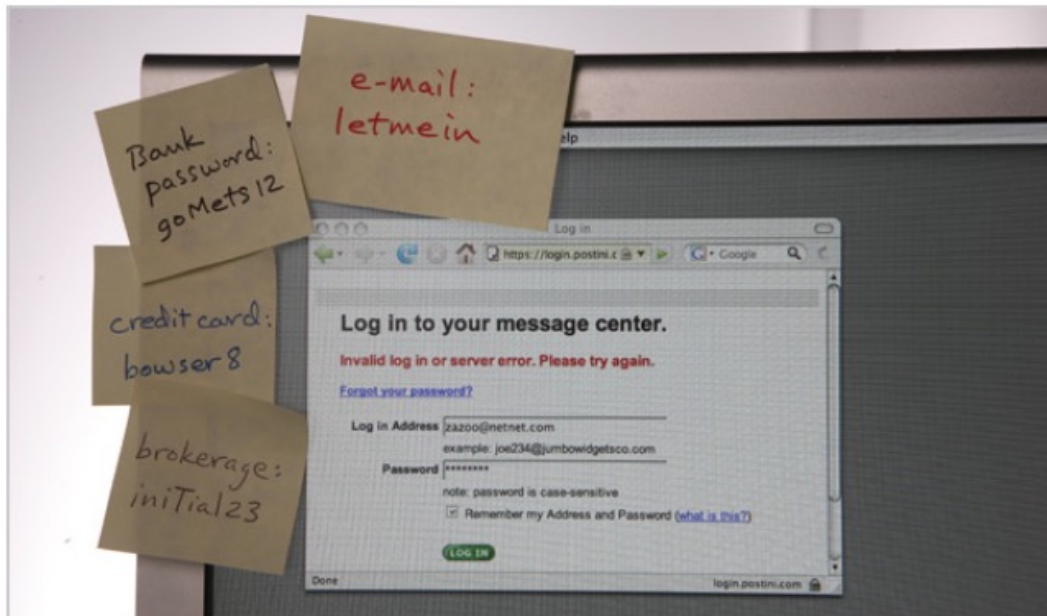
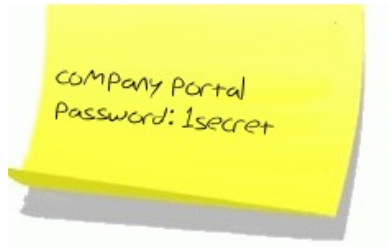
L'être humain ne peut pas

- se rappeler de quelque chose
 - utilisée de manière infrequente
 - qu'on a besoin de changer fréquemment
 - plusieurs et similaires
 - sans un « un sens »...créer un mot qui a un sens est plus difficile
- Oublier on-demand
- Se rappeler est plus difficile que reconnaître

Le mot-de-passe est la forme d'authentification la plus inefficace???

Challenges avec Mot-de-Passe

Difficile a se rappeler...**aide mémoire!**



Challenges avec Mot-de-Passe

Le mot-de-passe doit être long et complexe pour rendre difficile le « guessing ».

- Ceci rend la mémorisation difficile
- Solutions:
 - Choisir un mot de passe facile!
 - Ecrire le mot de passe sur une feuille!
 - Les deux

Le principe d'impossibilité du mot de passe:

« *Choisir un mot de passe dont tu ne peux pas te rappeler et ne l'écrit pas sur un bout de papier* »

Challenges avec Mot-de-Passe

TOP 30 PASSWORDS CRACKED

941	link	95	jesus	46	dragon
435	1234	91	connect	45	soccer
294	work	85	fu*k^	32	killer
214	god	78	monkey	32	654321
205	job	76	123456	31	pepper
179	12345	72	master	30	devil
176	angel	65	b*tch^	29	princess
143	the	60	d*ck^	28	1234567
133	ilove	52	michael	26	iloveyou
119	sex	48	jordan	26	career

^ WORDS AMENDED FOR PUBLICATION. FEEL FREE TO USE YOUR IMAGINATION ©

Top 25 Passwords Used

1.	123456	No Change
2.	password	No Change
3.	12345678	Up 1
4.	qwerty	Up 1
5.	12345	Down 2
6.	123456789	No Change
7.	football	Up 3
8.	1234	Down 1
9.	1234567	Up 2
10.	baseball	Down 2
11.	welcome	New
12.	1234567890	New
12.	1234567890	Up 1
14.	111111	Up 1
15.	1qaz2wsx	New
15.	1qaz2wsx	Down 7
17.	master	Up 2
18.	monkey	Down 6
19.	letmein	Down 6
20.	login	New
21.	princess	New
22.	qwertyuiop	New
22.	qwertyuiop	New
24.	passw0rd	New
25.	starwars	New
25.	starwars	New

Complex Passwords

UNCOMMON (NON-GIBBERISH) BASE WORD ORDER UNKNOWN Tr0ub4dor &3 CAPS? COMMON SUBSTITUTIONS NUMERAL PUNCTUATION (YOU CAN ADD A FEW MORE BITS TO ACCOUNT FOR THE FACT THAT THIS IS ONLY ONE OF A FEW COMMON FORMATS.)	~28 BITS OF ENTROPY $2^{28} = 3 \text{ DAYS AT } 1000 \text{ GUESSES/SEC}$ (PLAUSIBLE ATTACK ON A WEAK REMOTE WEB SERVICE. YES, CRACKING A STOKEN MESH IS FASTER, BUT IT'S NOT WHAT THE AVERAGE USER SHOULD WORRY ABOUT.) DIFFICULTY TO GUESS: EASY	WAS IT TROMBONE? NO, TROUBADOR. AND ONE OF THE O's WAS A ZERO? AND THERE WAS SOME SYMBOL... DIFFICULTY TO REMEMBER: HARD
correct horse battery staple FOUR RANDOM COMMON WORDS	~44 BITS OF ENTROPY $2^{44} = 550 \text{ YEARS AT } 1000 \text{ GUESSES/SEC}$ DIFFICULTY TO GUESS: HARD	THAT'S A BATTERY STAPLE. CORRECT! DIFFICULTY TO REMEMBER: YOU'VE ALREADY MEMORIZED IT
THROUGH 20 YEARS OF EFFORT, WE'VE SUCCESSFULLY TRAINED EVERYONE TO USE PASSWORDS THAT ARE HARD FOR HUMANS TO REMEMBER, BUT EASY FOR COMPUTERS TO GUESS.		

Challenges avec Mot-de-Passe

L'être humain ne peut pas

- se rappeler de quelque chose
 - utilisée de manière infrequente
 - qu'on a besoin de changer fréquemment
 - plusieurs et similaires
 - sans un « un sens »...créer un mot qui a un sens est plus difficile
- Oublier on-demand
- Se rappeler est plus difficile que reconnaître

Le mot-de-passe est la forme d'authentification la plus inefficace???

- ➔ **Nouvelles formes d'authentification**
 - Plusieurs étapes
 - Biométrie
- Principe:**
- Quelque chose qu'on connaît
 - Quelque chose qu'on a
 - Quelque chose qu'on est

Que Faire Quand on l'Oublie?

Récupération de mot de passe

- **Security Questions**
 - L'être humain a de la peine avec plus de 7 choix → au plus 5 questions
 - Nom de jeune fille de la maman
 - Lieu de naissance
 - ...
- **Cookies et cache des navigateurs**
 - Ne change pas ton ordinateur/navigateur
 - Trouble pendant les voyages
 - Solutions: Chrome login!

Challenges avec Mot-de-Passe

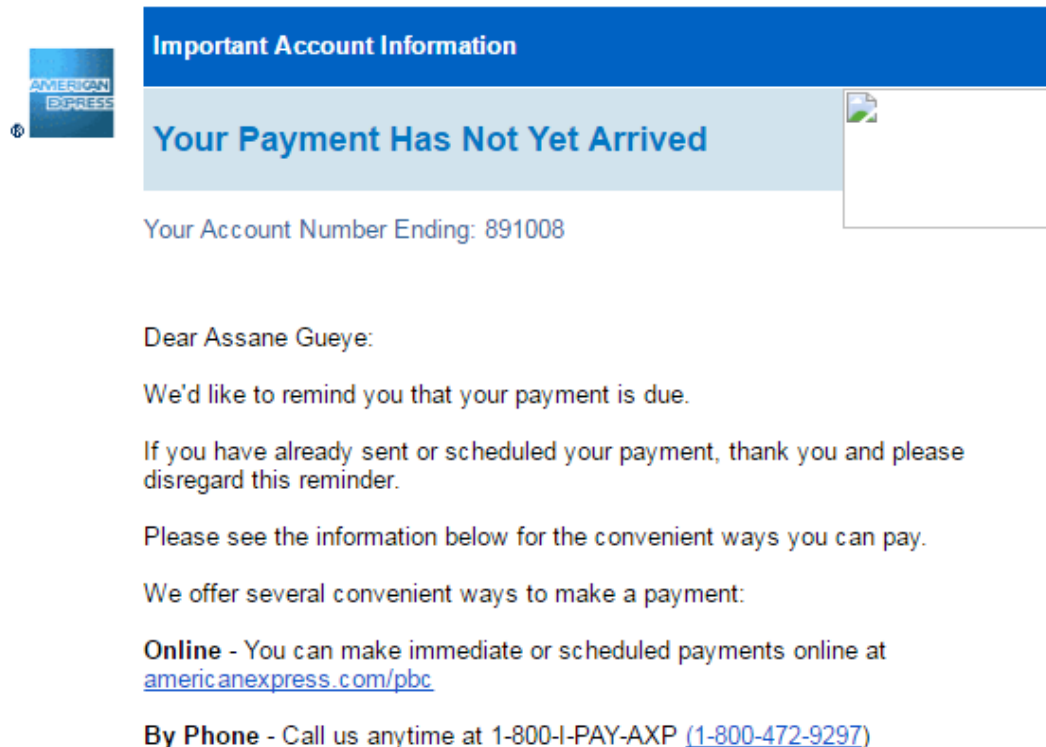
Quelque fois ce n'est pas l'être humain qui est le problème

- **Mot de passe par téléphone**
 - Numéro de téléphone vers un standard pour la maintenance des mots de passe!
➔ hack de l'email du Duke de Edinburgh
- **Login/Mot de passe par défaut**
 - Login: « admin »
 - Mot de passe: « admin », « 000000 », « 999999 » etc...
 - Beaucoup de systèmes tournent avec le mot de passe par défaut pendant des années.

Challenges avec Mot-de-Passe

Quelque fois ce n'est pas l'être humain qui est le problème

- **Message inconsistent de par les banques/business**
 - Ne donne pas tes infos au téléphone...cependant on continue de nous demander nos informations...pour des raisons de sécurité
 - Ne clique pas sur le lien d'un email...cependant....



Challenges avec Mot-de-Passe

Quelque fois ce n'est pas l'être humain qui est la SEULE SOURCE de problèmes

- **Etude a l'université de Sidney [1]**
 - 336 étudiants en info reçoivent un email leur demandant de donner leur mot de passe sous prétexte qu'on a besoin de revalider les mots de passe après une attaque informatique
 - 138 retournent leur mot de passe sans question
 - 30 voient l'email suspect, mais quand même donnent leur mot de passe
 - 200 vont changer leur mot de passe sans avis officiel

[1] T Greening, "Ask and Ye Shall Receive: A study in Social Engineering", in SIGSAC Review, volume 4, no 2, 1996

Attaques sur les Mot-de-Passe

- **Shoulder surfing**
 - Camera au dessus les GAP
- **Ecoute du canal**
 - Wifi
- **« Timing Attack »**
 - Utilisation du temps de réponse pour deviner le mot de passe
- **Stockage du mot de passe**
 - **Craquage de mot de passe**
 - Attack par dictionnaire
- **Denis de service pour l'utilisateur**
 - Entrer plusieurs fois le login de « alpha1 » avec un mot de passe aléatoire.

Stockage des Mot-de-Passe

- **Stockage en texte clair**
 - Mot-de-passe sauvé comme entré par l'utilisateur dans base de données
 - Quand l'utilisateur entre son mot-de-passe: il vérifié contre information sur base de données.
- Moyen de stockage la plus faible
- Si quelqu'un « hack » la base de données, tous les mots-de-passe sont compromis
- « Obsolète »

Stockage des Mot-de-Passe

- **Cryptage du mot-de-passe**
 - Mot-de-passe encrypté avec clef secrète avant d'être stocker
 - Si attaquant « hack » la base de données, il a aussi besoin de la clef
 - **Problème:** clef souvent stockée sur même serveur avec fichier de mot-de-passe
 - « Obsolète »

Stockage des Mot-de-Passe

- Hashage du mot-de-passe
 - Similaire a encryption
 - Mais avec fonction a un seul sens
- Si quelqu'un a le hash, il ne peut pas retrouver le mot-de-passe
- Attaquant peut cependant activer une « collision attack »

Stockage des Mot-de-Passe

- Hashage du mot-de-passe + « sel »
 - « Sel »: chaine de caractères aléatoires ajoutée au mot-de-passe avant hashage
- Diffèrent sel pour chaque mot-de-passe
- « Sel » est tres difficile a deviner
- « Brute force attack » toujours possible mais prend bcps de temps...cependant, a risque pour attaquant dévoué, avec bcps de moyens.
- « Assez standard » en ce moment

Attaques sur Mot-de-Passe

- Ingénierie Sociale
 - Le Demander directement a l'utilisateur
 - Utiliser la déception/tromperie pour avoir le mot-de-passe

Attaques sur Mot-de-Passe

- Acquisition directe:



Attaques sur Mot-de-Passe

- Acquisition directe:



Attaques sur Mot-de-Passe

- Acquisition directe:



Attaques sur Mot-de-Passe

- Systèmes indiscrets

```
BIENVENUE AU SYSTEME D'INFORMATION XYZ  
ENTREZ VOTRE NOM D'UTILISATEUR: assane  
ACCES INVALIDE, PAS D'UTILISATEUR AVEC CE NOM!  
ENTREZ VOTRE NOM D'UTILISATEUR :
```

Attaques sur Mot-de-Passe

- Systèmes indiscrets

```
BIENVENUE AU SYSTEME D'INFORMATION XYZ  
ENTREZ VOTRE NOM D'UTILISATEUR : assane  
ENTREZ VOTRE MOT DE PASSE: ****  
ACCES INVALIDE!  
ENTREZ VOTRE NOM D'UTILISATEUR:
```

Attaques sur Mot-de-Passe

- Systèmes indiscrets

```
ENTREZ VOTRE NOM D'UTILISATEUR : assane  
ENTREZ VOTRE MOT DE PASSE: ****  
ACCES INVALIDE!  
ENTREZ VOTRE NOM D'UTILISATEUR : laminegueye  
ENTREZ VOTRE MOT DE PASSE: ****  
BIENVENUE AU SYSTEME D'INFORMATION XYZ
```

Attaques sur Mot-de-Passe

- Brute Force

Essayer tous les mots de passe possible!

- Si mot-de-passe est formé avec les 26 lettres A-Z et a-z a une longueur entre 1 et 8
 - 26^1 mot-de-passe de longueur 1
 - 26^2 mot-de-passe de longueur 2
 - ...
 - 26^8 mot-de-passe de longueur 8
- $26^1 + 26^2 + \dots + 26^8 = 26^9 - 1$ mot-de-passe possibles
- $5 \cdot 10^{12}$ mot-de-passe
- Si on fait un test par milliseconde → 150 ans pour tout tester
- Si on fait un test par microseconde → 2 mois pour tout tester
- Si on a un Core Dual...
- Et si on optimise...

Attaques sur Mot-de-Passe

- Essayer de deviner le mot-de-passe

Pense a un mot!

Quelle est sa longueur?

Est-ce que c'est un mot pas très commun?

Est-ce que c'est un mot difficile a épeler?

Les utilisateurs préfèrent des mot-de-passe courts

➔ il faut 8 min pour craquer un mot de passe de longueur 4 (3.5 heures pour longueur 5)

Les utilisateurs préfèrent des mots communs (dans le dictionnaire)

Dictionnaire de 80'000 mots ➔ 80 seconds pour craquer le mot de passe

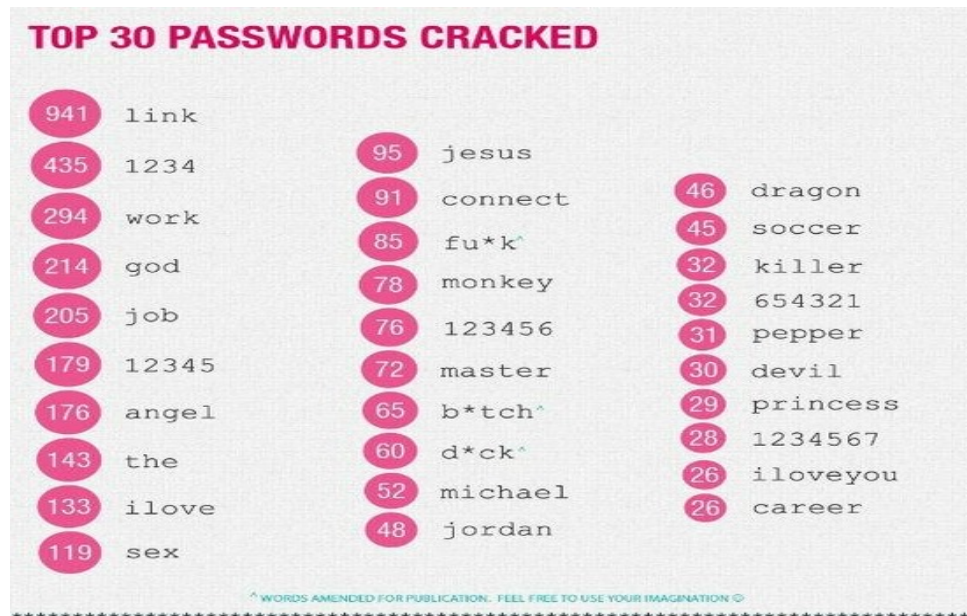
Attaques sur Mot-de-Passe

- Lire la mémoire de l'utilisateur

Les utilisateurs utilisent des mot-de-passe plutôt personnels

- Nom d'un membre de la famille: fils/fille, époux/épouse, frère/sœur, ami(e)...
- Souvenirs: ville, rue, projet, voiture,...

Il y'a seulement qlq dizaines de mots de ce genre...**même sans l'ordi on y arrive!**



Attaques sur Mot-de-Passe

- Attaquer le fichier des mot-de-passe
 - Stockage en texte clair: **merci pour le cadeau!**
 - Cryptage des mot-de-passe:
 - Vol de la clef, attaque exhaustive de la clef
 - Profiter du lapse de temps avant le cryptage
 - Hashage du mot-de-passe
 - « Collision attack »

Critères de Choix pour Mot-de-Passe

- Choix de l'alphabet
 - Avec les 26 lettres de l'alphabet, il faut 100 heures pour craquer un mot-de-passe de longueur 6
 - Si on fait majuscules+minuscule+chiffres (0-9) → 2 ans
 - Si on ajoute les caractères spéciaux → des centaines d'années
- Choisir des mot-de-passe longs
 - L'explosion « combinatoire » commence à 4 et 5
- Eviter les noms et mots du dictionnaire
 - Il y'a $26^6 \sim 300M$ de mot-de-passe possible de longueur 6
 - Le dictionnaire contient seulement 150'000 mots de longueur 6
- Choisir des mot-de-passe pas facile à deviner
 - « 2Brn2B » = « to be or not to be »
 - « l10veu » = « I love you »

Critères de Choix pour Mot-de-Passe

- Changer fréquemment de mot-de-passe
 - « Reset Button »
- Ne jamais l'écrire sur un bout de papier
 - Oui! Pas cet autocollant sur ton ordi!
- Ne jamais le partager
 - Le mot-de-passe est comme un sous-vêtement...ca ne se partage pas!
- Utiliser un « One Time Pad » tant que possible
 - La seule clef parfaite!

Choix du Mot-de-Passe

- Utiliser chiffre+lettre(M&m)+caractères spéciales
- Remplacer lettre/chiffre par caractère spéciale leur ressemblant (**Exemple: () pour O; Exemple: | 2 pour r**)
- Choisir un mot de passe long (difficulté quand > 7)
- Associer mot de passe a un mnémonique qui a du sens pour faciliter la mémoire

Exemple: “one fish two fish red fish blue fish” qui donne ()F2f|Fbf;

Exemple: “I-40 was slow as molasses this morning” qui donne I4()W\$aMtM

- Eviter noms et mots du dictionnaire
- Changer régulièrement
- Ne pas l’écrire sur un bout de papier (sinon le garder dans un lieu sécurisé)
- Créer différents mots de passe pour des comptes/applications différents
- Utiliser un « manager de mot de passe »
(<http://lifehacker.com/5042616/five-best-password-managers>)
- Ne jamais le partager



PinkEY Doesn't Open E-Mail From STRANGERS.

SHE ALSO DOES NOT SEND FILES ENDING IN:

.VBS, .SHS, .SCR, .EXE, .BAT, .COM, .PIF, .LNK, .SHB, .VB, .WSH, .WSF, .WSC, .SCT, OR .HTA,
AS ATTACHMENTS TO HER EMAILS.

<http://www.ihs.gov/cio/itsecurity/posters/index.cfm>



Information Technology Security

SPONSORED BY INDIAN HEALTH SERVICE



PINKEY USES IT SECURITY. HER PC IS BEHIND A FIREWALL.

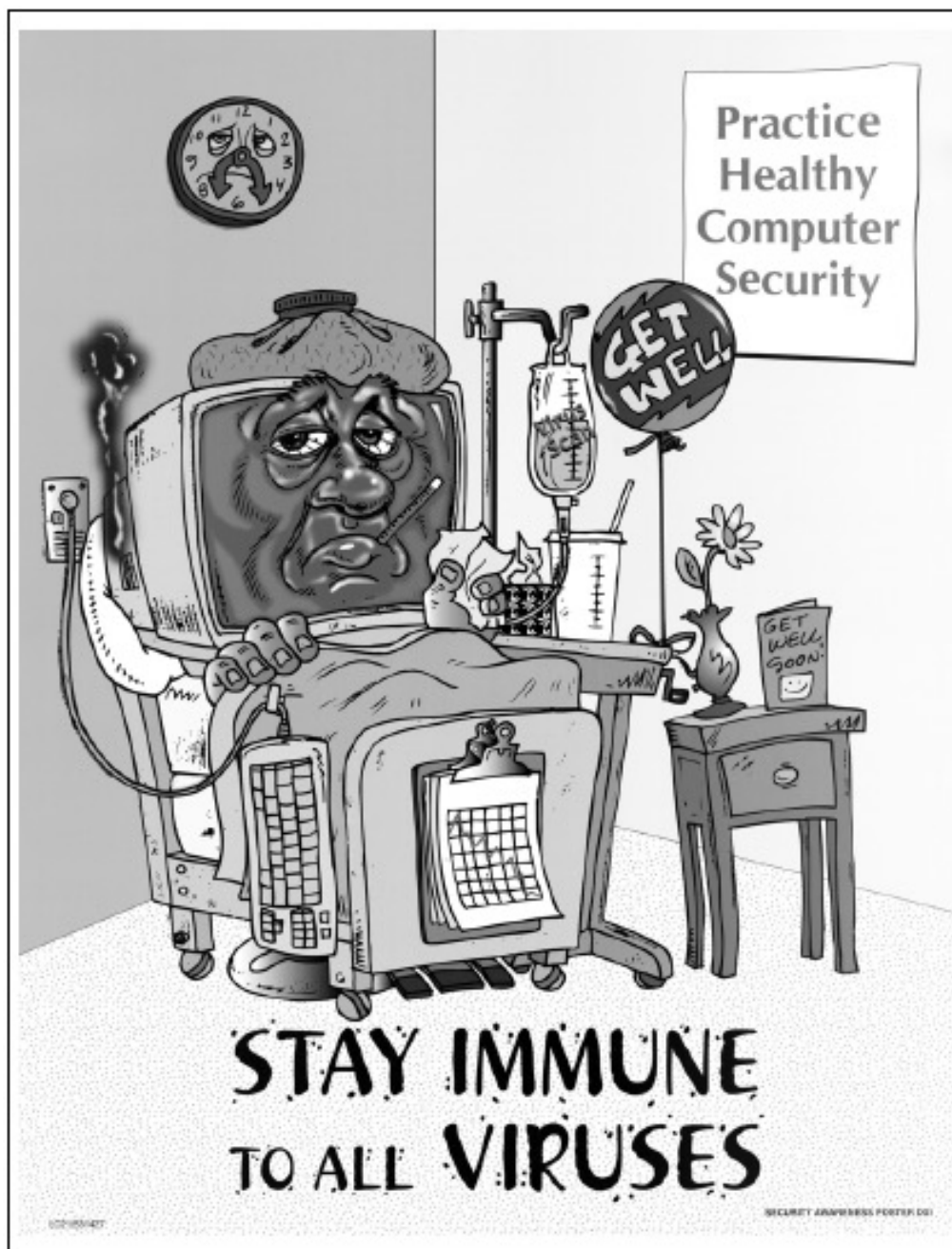
**AND SHE KEEPS THE MOST CURRENT VERSION OF HER ANTI-VIRUS SOFTWARE INSTALLED.
RINKEY AND DINKEY DON'T.**

<http://www.its.gov/cio/itsecurity/posters/index.cfm>

ITS

Information Technology Security

Developed by Brian Hall in Seattle



Practice
Healthy
Computer
Security

GET
WELL

GET
WELL
SOON

STAY IMMUNE
TO ALL VIRUSES



INFORMATION
SECURITY
...is good Business
Survival Tools & Techniques

Information Security Tips

1. Use strong passwords.

Any word that can be found in a dictionary is a bad password. Use numbers, letters, punctuation marks, and symbols. (Example: P4\$w0rd instead of Password or 43110_2_u instead of hello to you.)

2. Backup your important information.

Save early and save often. ALL important files should be stored on disks or CDs.

3. Use virus protection software.

That means three things: install it, use it, and keep it updated. Schedule your software to automatically scan all of your computer files regularly.

4. Do not keep computers online when not in use.

Either shut them off or physically disconnect them from the Internet connection.

5. Do not open email attachments from strangers,

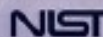
regardless of how tempting the subject line or attachment may be. Be suspicious of any unexpected email attachment even from someone you DO know because it may have been sent without that person's knowledge from an infected machine or they may be sending an infected file without knowing it.

FOR ADDED SECURITY

6. Use a firewall.

Firewalls are usually software products. Install it and set it up to allow only the services you want. (Example: Email, Web surfing, etc.) Firewalls are essential for those who keep their computers online through the popular DSL and cable modem connections but they are also valuable for those who dial in.

Regional Information Security Workshops are cosponsored by the National Institute for Standards and Technology, Small Business Administration, and the National Infrastructure Protection Center InfraGard program.



National Institute of Standards and Technology • Technology Administration • U.S. Department of Commerce

The support given by SBA, NIST and InfraGard to this activity does not constitute an express or implied endorsement of any company's or participant's opinions, products or services. All SBA, NIST and InfraGard programs are extended to the public on a non-discriminatory basis.

Prochainement

Vulnérabilité des Applications et
Protocoles!